Lab 21 — SSH Hardening + Fail2ban

You will switch SSH to key-only authentication and auto-ban brute-force IPs with Fail2ban.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free, apt): - `openssh-server` (pre-installed) - `fail2ban`

Step 1 — Install Fail2ban

```
apt update && apt install -y fail2ban
```

Step 2 — Generate a key pair (no passphrase for the lab)

```
ssh-keygen -t ed25519 -f ~/.ssh/lab_ed25519 -N "" -C "lab-key"
mkdir -p ~/.ssh && cat ~/.ssh/lab_ed25519.pub >> ~/.ssh/authorized_keys
chmod 600 ~/.ssh/authorized_keys
```

`ed25519` is the modern recommendation — short keys, fast, side-channel resistant.

Step 3 — Harden sshd

```
cat > /etc/ssh/sshd_config.d/99-hardening.conf <<'EOF'

PermitRootLogin prohibit-password

PasswordAuthentication no

PubkeyAuthentication yes

KbdInteractiveAuthentication no

MaxAuthTries 3

LoginGraceTime 20

ClientAliveInterval 300

ClientAliveCountMax 0
```

```
AllowUsers root

EOF

systemctl restart ssh
```

Confirm key login works and password is rejected:

```
ssh -i ~/.ssh/lab_ed25519 -o StrictHostKeyChecking=no root@127.0.0.1 'echo OK'

ssh -o PubkeyAuthentication=no root@127.0.0.1 2>&1 | head -2
```

Step 4 — Configure Fail2ban for sshd

```
cat > /etc/fail2ban/jail.d/sshd.local <<'EOF'

[sshd]

enabled  = true

port     = ssh
```

```
filter   = sshd

backend  = systemd

maxretry = 3

findtime = 5m

bantime  = 1h

EOF

systemctl restart fail2ban

fail2ban-client status sshd
```

Step 5 — Trigger a ban

```
for i in 1 2 3 4 5; do ssh -o PubkeyAuthentication=no -o
StrictHostKeyChecking=no \
```

```
  baduser@127.0.0.1 2>/dev/null; done

sleep 5

fail2ban-client status sshd

iptables -L f2b-sshd -n
```

You should see `127.0.0.1` in the banned list.

Step 6 — Unban (admin override)

```
fail2ban-client set sshd unbanip 127.0.0.1
```

Free online tools

- **SSH key best-practice (Mozilla)** — https://infosec.mozilla.org/guidelines/openssh
- **Fail2ban docs** — https://www.fail2ban.org
- **CrowdSec community** (alternative to fail2ban) — https://www.crowdsec.net
- **AbuseIPDB** — https://www.abuseipdb.com

What you learned

- Why password auth is the #1 risk on internet-exposed SSH.
- The two configuration knobs that defeat 99% of SSH brute force.
- How Fail2ban wires its bans into the live iptables ruleset.